

Component 2: User Login

xPostForecast · Milestone 4: Component-Level Design · Pseudocode

Where it runs Backend: POST /auth/login (backend/routes/auth.js)

User stories US-2, US-3

Flowchart Component2_Login_Flowchart.pdf

Description

Checks a username and password and, if they match, starts a one-hour session by setting a signed token in an HTTP-only cookie.

Design principles

Information hiding. The component reveals as little as possible. An unknown username and a wrong password produce the same 401 "Invalid credentials" response, so callers can't discover which usernames exist. The session token is sent only in an HTTP-only cookie, never in the response body, so page scripts can't read it.

Functional independence (high cohesion, low coupling). The cookie settings are chosen in one small, single-purpose module (config/cookies.js) that both login and logout use. Login depends only on that module's answer, not on how production and development differ, so the cookie policy can change without touching the login logic.

Pseudocode

```
BEGIN LoginUser
  IF this address has made more than 20 attempts in the last 15 minutes THEN
    RESPOND 429 "Too many attempts. Please wait 15 minutes and try again."
    STOP
  END IF

  READ username, password FROM the request body

  IF username or password is missing THEN
    RESPOND 400 "username and password are required"
    STOP
  END IF

  LOOK UP the user whose username matches (id, username, passwordHash)

  IF the lookup failed THEN
    LOG the error
    RESPOND 500 "Failed to login"
    STOP
  END IF

  IF no user was found THEN
    RESPOND 401 "Invalid credentials"
    STOP
  END IF
```

```
IF password does not match the user's passwordHash (bcrypt compare) THEN
    RESPOND 401 "Invalid credentials"
    STOP
END IF

SET token TO a JWT holding the user's id and username,
    signed with JWT_SECRET and expiring in 1 hour

IF the server is running in production THEN
    SET cookieFlags TO HttpOnly, Secure, SameSite=None, Partitioned
ELSE
    SET cookieFlags TO HttpOnly, SameSite=Lax
END IF

SET the cookie "token" TO token WITH cookieFlags, lasting 1 hour
RESPOND 200 "Login successful"
END LoginUser
```